

P03 Block 3 code requalification — 2026-09-23

Status: **local code and integration checks passed; release and external review checkpoints pending**. This report requalifies the historical P03 storage/recovery receipt against the current release Stack 03 candidate. It does not close the known erase-before-replacement power-interruption risk or promote a release branch.

Frozen identity and scope

Item	Identity
Predecessor	P02 code-bearing head 9237d0a30004dbc079dcf3c1577b2895bc50c73a (PR #855)
Live product source	release/715-stack-03-recovery head 2e008f8527f663107922835dbc8761333b8f073f (PR #833), replayed as 210e5e155
Historical receipt	P03 PR #851 head 5b5a9c1b196f82a6a98e07f6ba2729560aeafe89; its final reviewed diff contained three evidence files and no firmware code
Replayed local AdvancedMode fix	Historical c2ddc065606df576f5c546259b6811e64f4de2a2, reconciled for both variants and ARM at e4dbc6caa312db1f0f24569b7494ac1f283b5ddc
BIP-85 hardening	2b1be1e6203ebf148aa9425844a74624991657c0
Frozen code tree	e6d906266ce5583f3fcf559a77a0308dace7838e (format-only delta from locally tested tree)
Build source	Isolated branch audit/p03-requalification-20260923; no shared develop mutation
Code-bearing review surface	PR #857 , targeting the P02 reviewed branch

The product source adds BIP-85 on-device child mnemonic display, message registration, reset/recovery cleanup and response arena changes. The prior P03 scope's nine retained storage, setup and recovery units were traced in current source and exercised by the suites below. Its four withdrawn durability-specific units remain withdrawn. Direct gitlink pins: code-signing-keys a6470bd8598e5e9a7bfc38bf139a5e5a616f05ec; deps/crypto/trezor-firmware 8a392f70a5d5575ece3dfb35f115d4a4b27f497c; deps/device-protocol dd9c85dc747cf965fb0e7bf49615dc9e7568ee65; deps/googletest 7888184f28509dba839e3683409443e0b5bb8948; deps/python-keepkey ea385cf6fdd5c22e2c3ea384578777fb9c9d127; deps/qrenc/QR-Code-generator 6dfbfdad5d9303ed190d1c3cb7bec34b565b6ce8; deps/sca-hardening/SecAESSTM32 71d356a1141624994cf613bd2d2583892e8e6d5a.

Findings and dispositions

ID	Finding on selected candidate	Disposition and distinguishing evidence
P03-01	Inherited AdvancedMode could round-trip through unauthenticated flash bit 12 or a legacy stored policy name, though authorization is session-only.	Replayed the local fix: V11/V16/V17 readers ignore the bit, writers clear it, stale V17 records scrub it, and lock clears runtime policy/signers. Three native storage regressions passed in both variants. The first replay failed Bitcoin-only linking and non-debug full ARM compilation; both were fixed before acceptance.
P03-02	BIP-85 is registered in both variants but was omitted from the Bitcoin-only setup-ceremony abort switch.	Moved its dispatch case outside the full-build guard. Native ceremony and wire-registration checks passed in both variants.
P03-03	DebugLinkState returned child words as screen pixels while BIP-85 said the words were displayed only on-device; DebugLinkFlashDump could read memory during that display.	Entire DebugLinkState is empty and FlashDump is refused during the private display. The screen is cleared to home before diagnostics resume on success or cancellation. Host wire checks passed for both variants; native FlashDump refusal passed.

ID	Finding on selected candidate	Disposition and distinguishing evidence
P03-04	The pinned BIP-85 host file's six tests all skip because this candidate advertises firmware 7.14.3; it also requires full-feature firmware.	Added capability-based host tests for 12/18/24-word flows, invalid parameters, private display and cancellation, and native published BIP-85 vectors for 12/18/24 words, repeatability and index separation. The six original skips remain visible, not counted as passes.
P03-05	The inherited storage sector rotation erases before replacement is durably recorded; power loss in that interval can lose the wallet.	Open and deferred under the owner's prior scope correction. Reboot and migration passes do not prove power-interruption safety. No durability redesign was made.

Sensitive-value contract and falsification

Value or state	Origin and phase	Allowed output	Forbidden observer/output	Executed assertion
AdvancedMode authorization	Unlocked session after user authorization, then lock/restart	Active only in that session	Flash V11/V16/V17 policy bit or legacy policy string; locked runtime signers	Three native storage tests in both variants
BIP-85 child words and their encoded pixels	Root-node derivation after confirmation, through every word page and abort	Device OLED after user consent	Main wire payload, DebugLinkState fields/layout pixels, FlashDump memory	Published native vectors; host full-page DebugLink reads and post-exit home-layout equality; native FlashDump denial
Armed setup/recovery ceremony	Before BIP-85 request dispatch	Aborted before child derivation	Retained setup/recovery authorization after an unrelated request	Native AutoLockProgress.Bip85RequestEndsAnArmedCeremonyInBothVariants

The independent BIP-85 oracle is the [published BIP-85 BIP-39 English vectors](#), decoded from their root xprv only in a debug-only native fixture. It does not read child words or screen pixels through DebugLink. The test fixture symbol is absent from both KK_DEBUG_LINK=OFF ARM binaries. Counterexamples exercised: another debug channel (FlashDump), alternate representation (screen pixels), cancellation after a private page, Bitcoin-only dispatch, invalid word count/index, and changed index. Physical OLED photography and power-cut injection were not performed.

Executed evidence on the frozen code

Pinned builder: `kktech/firmware@sha256:7438e53933d47d53157ed6d96d864cb208597e62dce26235ace09d1063427fa2`; builds used source mounted read-only, separate build directories and `--network none`. The host test image was `kk715block2-python-keepkey:latest`. Local logs and binaries are retained in `/private/tmp/kk715-p03-evidence`.

Check	Full	Bitcoin-only
Native make xunit	460 firmware, 20 board, 18 crypto, 72 Zcash passed	155 firmware, 20 board, 18 crypto passed
Host suite on owned emulator	587 passed, 253 skipped, 0 failed	354 passed, 486 skipped, 0 failed
Storage power-cycle cases within host suite	5 passed, 0 skipped	5 passed, 0 skipped
New BIP-85 host checks after fixture expansion	5 passed	5 passed
Updated native vector fixture after index checks	1 passed	1 passed
Shipping ARM MinSizeRel, KK_DEBUG_LINK=OFF	linked; 21,332-byte _ebss-_stack gap	linked; 35,360-byte gap

The ARM linker enforces at least 16 KiB of runtime stack/heap reserve. Full ARM size was text 583,984, data 3,428, bss 104,252 bytes; Bitcoin-only was text 343,728, data 3,284, bss 90,368 bytes. `bip85_derive_from_root_for_test` and `DebugLink` handlers were absent from the shipping symbols. Native `SetupCeremony` (nine cases), stored-string bounds, Bitcoin-only band refusal, staging/foreign-commit, and sector-local erase cases executed. Host recovery/backspace and five owned-emulator storage reboot cases executed. The original six `test_msg_bip85.py` tests skipped due to the version gate; the new tests cover their applicable flow/validation paths and the native fixture checks derived output without violating the debug privacy contract.

Evidence SHA256: full native log `14da47f6206117f747e143bd6ad826d0ec877c8661554c77e3d084d628528801`; Bitcoin-only native `1ad782e5059660968fdd3cfe5dfabd3a4b0badd02d2f16b4f060df2e1d0c4986`; full host

ce2954619b631df04535f0f89573d041fa9fdb953578c1df9ae880287b41e60a; Bitcoin-only host
8ac7e9ec6030a8d47cc2f874f954a97dd0f6864f69b4a751cbe733970faf7491. Full ARM ELF
025a2909756d683b28b2c06c1fc87507b61c579324f5924f066eeaca4163586e; Bitcoin-only ARM ELF
f2d25cbba2ab5291016ac58f47dc1f242cab3a6f4ee4674f424fe080e3d5fa69.

Change inventory against P02 predecessor

Added	Deleted	Path
4	4	docs/firmware/reviews/7.15.0-review-round2-remediation.md
14	0	include/keepkey/firmware/bip85.h
1	0	lib/firmware/CMakeLists.txt
47	24	lib/firmware/bip85.c
32	2	lib/firmware/fsm.c
43	34	lib/firmware/fsm_msg_bip85.h
2	0	lib/firmware/fsm_msg_coin.h
5	0	lib/firmware/fsm_msg_common.h
8	8	lib/firmware/fsm_msg_debug.h
2	1	lib/firmware/fsm_msg_ethereum.h
1	0	lib/firmware/fsm_msg_ton.h
1	0	lib/firmware/fsm_msg_tron.h
179	255	lib/firmware/messagemap.def
7	1	lib/firmware/recovery_cipher.c
16	13	lib/firmware/storage.c
1	0	scripts/emulator/python-keepkey-tests.sh
14	9	tools/firmware/keepkey_main.c
81	0	unittests/firmware/fsm.cpp
75	1	unittests/firmware/storage.cpp
70	0	unittests/host/test_p03_recovery.py

The large messagemap.def line delta is mostly formatting; the semantic change adds two BIP-85 registrations and uses the equivalent `#if !BITCOIN_ONLY` condition. Product-source changes also correct response arena sizing and recovery word-fragment lifetime. The historical P03 receipt's documentation-only review cannot certify these code changes. The current PR diff and exact-head CI still require their own record.

Checkpoint state and next action

This report's frozen audit code tree passed local native/host, both ARM variants, and adversarial BIP-85 checks. CI run [35928940193](#) failed a format-only comment gate; corrected audit head `7fe634c90af2004d0830378438d59990e147c2df` passed run [35929132398](#). The ordinary merge into `release/715-stack-03-recovery` produced head `e2935558b5764f9c102408e9bf08b8ea833a82ee` with the **same code tree**; its exact-head run [35931704198](#) passed every required job. Audit PR #857 was closed after integration; product [PR #833](#) is the final review surface. The single owner-authorized Copilot review 5297949634 on that merge head returned **Changes recommended** and identified a recovery import contract defect plus evidence/test observations. Subsequent remediation and its CI are recorded on PR #833, not claimed by the pre-remediation runs above. Physical OLED/release testing remains pending. The inherited erase-before-replacement power-interruption risk remains open and deferred, not fixed or waived.